

Архком: Dify

Создана пользователем [Карбовничий Василий Юрьевич](#). Последнее обновление: [июл. 29, 2025](#) ([Каршибаев Руслан Исмаилович](#)) • Время чтения: 4 мин.

Название	Dify
Категория	Новый сервис
Автор	@ Карбовничий Василий Юрьевич
Докладчик	@ Карбовничий Василий Юрьевич @ Копосов Александр Сергеевич

- [Описание](#)
- [Архитектурная схема](#)
- [Данные](#)
- [Безопасность](#)

Анонс

Opensource low-code платформа для создания ИИ агентов

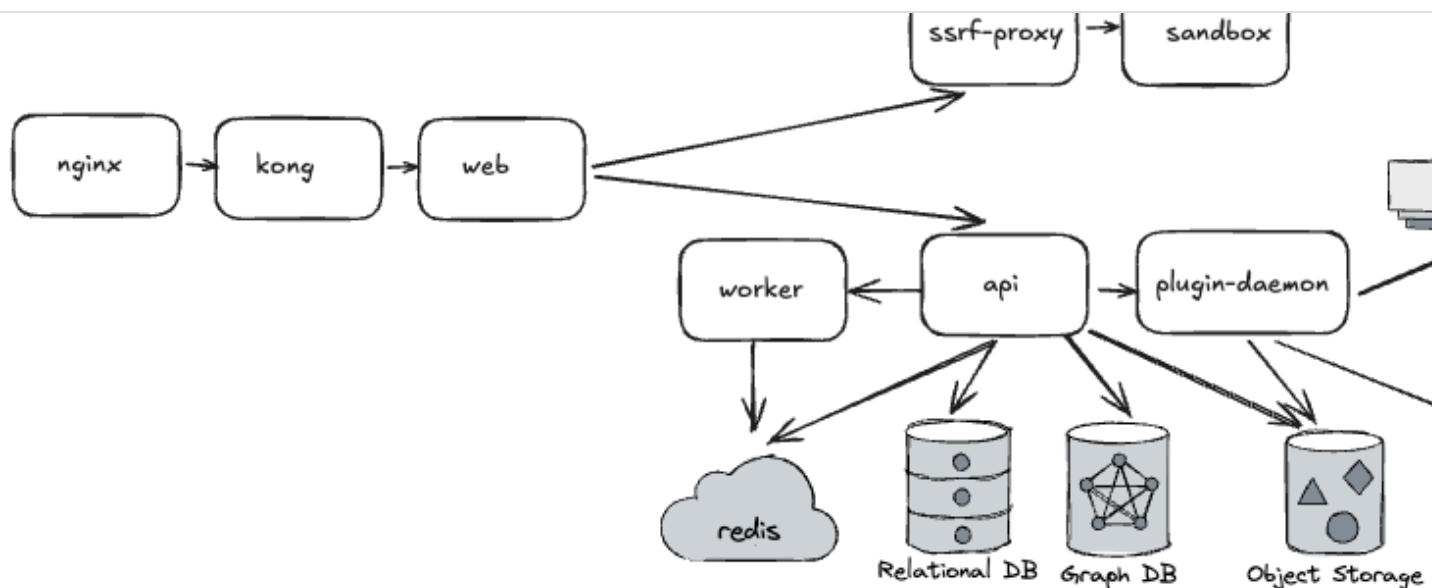
Описание

Dify предоставляет комплексное, готовое решение, хорошо продуманную систему строительных блоков, позволяет оптимизировать разработку решений на базе ИИ

Dify позволит:

- С минимальными затратами времени и ресурсов разворачивать различных агентов на базе LLM
- Проверять гипотезы с минимальными расходами
- Использовать встроенные механизмы RAG (поиск по собственным базам знаний)
- Использовать развернутые в компании оупенсорсные модели без расхода на токены
- Не нужно быть разработчиком, чтобы сконструировать своего агента

Dify не заменяет разработанное в компании решения по ИИ агентам, а дополняет его различными функциями, которых еще нет, и разрабатывать которые трудозатратно, а эффект от них не ясен



1. Dify Backend:

- a. API Service - обрабатывает запросы к API от Frontend service и контролирует доступ к API
- b. Worker Service: асинхронно выполняет длительные задачи например загрузка датасетов, очистка и другое

2. Dify Plugin Daemon менеджер плагинов. Позволяет подключать различные плагины, в том числе собственной разработки, например для подключения LLM, поисковые движки, обработка изображений и другое, пример плагинов из официального магазина <https://marketplace.dify.ai/>

- a. Плагины **Models**. Эти плагины интегрируют различные модели ИИ (включая основных поставщиков LLM и пользовательские модели) для обработки конфигурации и запросов к LLM API
- b. Плагины **Tools**. Это сторонние сервисы, которые могут вызываться приложениями Chatflow, Workflow или типа Agent. Они предоставляют полную реализацию API для расширения возможностей приложений Dify.
- c. Плагины **Agent Strategy**. Такой плагин определяет логику рассуждений и принятия решений в узле агента, включая выбор инструмента, вызов и обработку результатов.
- d. Плагины **Extensions**. Легковесные плагины, предоставляющие возможности для более простых сценариев, что позволяет быстро расширять их через HTTP-сервисы. Этот идеально подходит для простых интеграций, требующих базового вызова API.
- e. Плагины **Bundle** «Пакет плагинов» — это набор из нескольких плагинов.

3. Dify-Sandbox предлагает безопасный метод запуска кода, из неизвестных источников в изолированном пространстве, что ограничивает ресурсы и системные вызовы, к которым код может получить доступ

4. Dify ssrf proxy Прокси сервер защищающий от SSRF атак, используется для безопасного перенаправления запросов в Sandbox

5. Qdrant Vector database используется для быстрого поиска по Knowledge Base и для RAG

Данные

Схема базы данных, состав данных, признаки ПДн/КТ

dify имеет 2 базы данных, одна используется API, вторая менеджером плагинов (plugin-daemon)

СХЕМА api

3/7

Схема плагина

plugin_declarations id created_at updated_at A-Z plugin_unique_identifier A-Z plugin_id A-Z declaration	tenant_storages id created_at updated_at A-Z tenant_id A-Z plugin_id 123 size	agent_strategy_installations id created_at updated_at tenant_id A-Z provider A-Z plugin_unique_identifier A-Z plugin_id	ai_model_installations id created_at updated_at A-Z provider tenant_id A-Z plugin_unique_identifier A-Z plugin_id
tool_installations id created_at updated_at tenant_id A-Z provider A-Z plugin_unique_identifier A-Z plugin_id	install_tasks id created_at updated_at A-Z status tenant_id 123 total_plugins 123 completed_plugins A-Z plugins	serverless_runtimes id created_at updated_at A-Z plugin_unique_identifier A-Z function_url A-Z function_name A-Z type A-Z checksum	plugins id created_at updated_at A-Z plugin_unique_identifier A-Z plugin_id 123 refers A-Z install_type A-Z manifest_type A-Z remote_declaration
endpoints id created_at updated_at A-Z name A-Z hook_id A-Z tenant_id A-Z user_id A-Z plugin_id expired_at enabled A-Z settings	plugin_installations id created_at updated_at tenant_id A-Z plugin_id A-Z plugin_unique_identifier A-Z runtime_type 123 endpoints_setups 123 endpoints_active A-Z source A-Z meta		

Безопасность

Dify поддерживает Workspace, куда владелец добавляет членов команды

Владелец workspace обладает owner правами, роли членам команды выдаются по решению владельца

OWNER
ADMIN
EDITOR
NORMAL
DATASET_OPERATOR

Ролевая модель, аудит, логирование

Требования КБ:

1) Управление доступом

Пользовательская идентификация и аутентификация должна выполняться с использованием единых сервисов IdP.

Все пользователи должны проходить аутентификацию с использованием как минимум двух факторов (например, пароль + OTP).

Доступ к функциям платформы должен быть ограничен на основе ролей (администратор, оператор, разработчик, аудитор и т.д.). При этом пользователи должны получать доступ только к тем функциям и к тем данным, которые необходимы для выполнения их задач.

Все попытки аутентификации, как успешные, так и неуспешные, должны логироваться для дальнейшего анализа и расследования инцидентов.

2) Защита данных

Данные ИИ-агентов, пользовательские вводы, модели должны быть зашифрованы на уровне БД;

При передаче по сети должен применяться протокол TLS не ниже 1.3;

Чувствительные данные (например, ПДн) должны быть замаскированы, например, при помощи внешнего

Вводные данные должны проверяться на наличие вредоносного кода и/или инъекций;

Модели должны быть устойчивы к манипуляциям и adversarial examples (злонамеренная манипуляция входными данными с целью заставить ее выдать некорректный результат);

Модели должны быть защищены от несанкционированного копирования;

Модели должны быть защищены от отравления датасетов;

Должна быть возможность введения квот на количество и частоту обращений к моделям (rate-limiting);

Системные промпты должны быть защищены за счет частичного хардкодинга, фильтрации входных данных и валидаций. В системных промптах не должны храниться ключи доступа к смежным системам.

4) Сетевая безопасность и межсервисное взаимодействие

Интерфейс платформы должен быть доступен только внутри контура ДК, публикация приложения наружу не допускается.

Должны быть разделены среды разработки, тестирования и прода для минимизации рисков утечек;

Все запросы к API должны быть защищены с помощью аутентификации. Анонимные запросы запрещены.

Системы информационного обмена должны аутентифицировать и авторизовывать сетевой доступ друг друга посредством использования mTLS.

Необходимо использовать Service Mesh для организации сетевого взаимодействия микросервисов (взаимная аутентификация сторон и шифрование сетевого трафика).

Взаимодействие сервер-сервер должно быть закрыто токенами доступа.

Аутентификационная информация (сертификаты, токены, пароли и т.д.), предназначенная для использования сервисами, должна храниться в hashiCorp Vault.

Токены доступа к сервисам не должны храниться в базе данных в открытом виде.

Токены доступа должны быть выпущены конкретному сервису без возможности его переиспользования 3-им сервисом.

Запрещена реализация взаимодействий между промышленным сегментом (prod) и сегментом разработки (qa/stage).

5) Мониторинг и реагирование

Все запросы (prompts), ответы модели, ошибки и действия пользователей, а также метаданные должны логироваться (например, IP, user ID, timestamp);

Должно быть реализован механизм мониторинга аномалий (например, попытки реализации атак типа prompt injection);

В системе должно быть реализовано логирование, уровень логирования не ниже INFO. Уровень логирования выше (детальнее) INFO в пром контуре запрещен. В случае крайней необходимости более детальный уровень логирования на постоянной основе (Debug или trace) может быть согласован экспертами кибербезопасности при условии реализации митигирующих мер: маскирования чувствительных данных в логах (ПДн, секреты, токены и т.д.) и оценки достаточности логирования на уровне INFO. Временное (1-2 дня) включение более детального уровня логирования на проде для целей решения тикетов допустимо.

6) Пентест

Перед вводом в промышленную эксплуатацию система должна пройти тестирование на наличие уязвимостей (pentest), осуществляемое в соответствии с внутренним регламентом Домклик.

Обязательному тестированию подлежат все сервисы, выводимые в промышленную эксплуатацию.

Нет меток



июл. 29, 2025

1. Выглядит так что это архком на решение, а не сервис. Поэтому бы сравнительный анализ, и желательно демку
2. Схема БД – россыпь табличек. Точно ли в реляционной БД только одно отношение?
3. Нет конкретизации по технологиям - какая relationDB? ObjectStorage? GraphDB у нас поддерживается инфраструктурой?



Неизвестный пользователь (abbaymasheva)

июл. 29, 2025

Поддерживаю.



Горбунов Павел Вячеславович

июл. 29, 2025

3 - решение Quadrant, инфрой не поддерживается, обслуживается нами



Неизвестный пользователь (abbaymasheva)

июл. 29, 2025

без персистентного хранения данных ?



Еленская Нина Геннадьевна

июл. 29, 2025

Данный архком принимается для легализации Dify в контуре Домклик. Стандарт разработки ИИ агентов с целевой архитектурой платформы для этого будет приниматься отдельным архкомом с типом: новый стандарт.



Неизвестный пользователь (abbaymasheva)

июл. 29, 2025

Прошу ограничить использование сервиса и применять пилоты только для внутренних целей (аналитика, производственный процесс и др), так как "бизнесовые" агенты должны проходить валидацию банка перед использованием в проде.



Еленская Нина Геннадьевна

июл. 29, 2025

это же просто пилот, ограничения будут после принятия решения об использовании инструмента в целевой архитектуры



Неизвестный пользователь (abbaymasheva)

июл. 29, 2025

давай уточним где будет применять пилот



Еленская Нина Геннадьевна

июл. 29, 2025

Пилот будет применяться по процессам, которые не являются MC, и которые не влияют напрямую на внешних клиентов

В рамках архкома НЕ ПРИНИМАЕТСЯ решение об использовании Dify как стандарта разработки агентов



Неизвестный пользователь (abbaymasheva)

июл. 29, 2025

это не отвечает на вопрос об области использования пилота



Еленская Нина Геннадьевна

июл. 29, 2025

ответила



Мышко Егор Викторович

июл. 31, 2025

Как будет реализована безопасность инструментов? Например, если для работы инструмента нужно передавать ему идентификаторы которые могут представлять из себя ПДН. Будут ли эти идентификаторы уходить в LLM? Если да, то как это согласовывалось с КБ? Если нет то каким образом это реализовано?



Горбунов Павел Вячеславович

июл. 31, 2025

не применимо, т.к. модель развернута локально



Мышко Егор Викторович

июл. 31, 2025

Я правильно понимаю, что рассматриваются только локальные LLM'ки и подключение внешних моделей полностью исключено?



Горбунов Павел Вячеславович

июл. 31, 2025

все верно, только модели на нашем железе



Мышко Егор Викторович

авг. 03, 2025

Понял, спасибо.

Тогда не понятно почему требуется обфускация согласно пункту №2 требований КБ "*Чувствительные данные (например, ПДн) должны быть замаскированы, например, при помощи внешнего обфускатора*". Если это не применимо к тулам тогда это должно быть не применимо и к промптам. Или это как-то иначе интерпретируется?
